

MedGuard AI

Backend API — User Stories

Role: **Backend Lead**

Total User Stories: 30

Authentication & User Management (US-01 – US-06)

US-01 Register a New User Account

User Story

As a *new user*, I want to register with my name, email, and password so that I can access MedGuard AI medicine verification features.

API Endpoint

POST /api/server/auth/register/ Auth: **Public**

Example Request

```
{
  "name": "Sai Jagdale",
  "email": "sai@example.com",
  "password": "SecurePass@123"
}
```

Acceptance Criteria

- User can submit name, email, and password
- Email must be unique — duplicate returns 400
- Password is hashed before storage (never plain text)
- System validates email format
- Returns HTTP 201 with user record on success

Business Value

Enables new users to onboard onto the platform and access all verification features.

US-02 Login and Receive JWT Token

User Story

As a **registered user**, I want to log in using my email and password so that I receive a JWT access and refresh token to authenticate all subsequent requests.

API Endpoint

POST /api/server/auth/login/ Auth: **Public**

Example Request

```
{
  "email": "sai@example.com",
  "password": "SecurePass@123"
}
```

Acceptance Criteria

- Returns access token and refresh token on valid credentials
- Returns HTTP 401 on invalid credentials
- Tokens are signed JWTs with a defined expiry duration

Business Value

Provides secure session-based access to all protected API endpoints via JWT.

US-03 Refresh an Expired Access Token

User Story

As a **logged-in user**, I want to submit my refresh token to obtain a new access token so that I remain authenticated without needing to log in again.

API Endpoint

POST /api/server/auth/token/refresh/ Auth: **Public**

Example Request

```
{
  "refresh": "<refresh_token_here>"
}
```

Acceptance Criteria

- Returns a new access token when a valid refresh token is provided
- Returns HTTP 401 if refresh token is expired or invalid

Business Value

Improves user experience by enabling uninterrupted sessions without frequent re-login.

US-04 Logout and Blacklist Refresh Token

User Story

As a **authenticated user**, I want to log out from the platform so that my refresh token is blacklisted and my session is securely terminated.

API Endpoint

POST /api/server/auth/logout/ Auth: **JWT**

Example Request

```
{
  "refresh": "<refresh_token_here>"
}
```

Acceptance Criteria

- Requires valid JWT in Authorization header
- Blacklists the provided refresh token on logout
- Subsequent use of the blacklisted token returns HTTP 401
- Returns HTTP 200 with success message on valid logout

Business Value

Ensures secure session termination, preventing token reuse after logout.

US-05 View Authenticated User Profile

User Story

As a **authenticated user**, I want to retrieve my profile details so that I can see my account name, email, and role.

API Endpoint

GET /api/server/auth/profile/ Auth: **JWT**

Acceptance Criteria

- Returns name, email, role, and account creation timestamp
- Password field is never returned in the response
- Returns HTTP 401 if JWT is missing or invalid

Business Value

Gives users transparency into their own account information.

US-06 Update User Profile

User Story

As a **authenticated user**, I want to update my name or change my password so that I can keep my account information current and secure.

API Endpoint

PATCH /api/server/auth/profile/update/ Auth: **JWT**

Example Request

```
{
  "name": "Sai Rajendra",
  "password": "NewSecure@456"
}
```

Acceptance Criteria

- Only name and password fields are updatable
- New password is hashed before storage
- Returns HTTP 200 with updated profile on success

Business Value

Allows users to maintain accurate and secure account credentials.

Medicine Verification Module (US-07 – US-12)

US-07 Verify Medicine via Text Input

User Story

As a **user**, I want to type a medicine name to verify it so that I can check its authenticity, legality, expiry, and get an AI summary.

API Endpoint

POST /api/server/medicine/verify/text/ Auth: **JWT**

Example Request

```
{
  "medicine_name": "Paracetamol 500mg"
}
```

Acceptance Criteria

- User can submit a medicine name as text
- System runs RAG + FAISS semantic search
- Returns status: Authentic, Fake, Expired, Illegal, or Not Found

- Returns similarity score, legality, and AI-generated summary
- Response returned within 5 seconds under normal load
- Verification attempt stored in history

Business Value

Core feature — enables instant medicine authenticity check using just the medicine name.

US-08 Verify Medicine via Image Upload

User Story

As a **user**, I want to upload a medicine package image for verification so that the system automatically extracts and verifies medicine details from the photo.

API Endpoint

POST /api/server/medicine/verify/image/ Auth: **JWT**

Example Request

```
Form-data:
  image: <medicine_package.jpg>
```

Acceptance Criteria

- Accepts JPG/PNG medicine package image
- Sends image to Google Vision API for OCR extraction
- Extracts MFG date, EXP date, MRP using Regex
- Validates expiry against current date
- Runs RAG + FAISS search on extracted medicine name
- Returns structured result with all extracted fields

Business Value

Allows users to verify medicines from a photo, enabling real-world handheld usage.

US-09 Verify Medicine via Barcode

User Story

As a **user**, I want to submit a medicine barcode for instant verification so that I get a result without any manual text entry.

API Endpoint

POST /api/server/medicine/verify/barcode/ Auth: **JWT**

Example Request

```
{
  "barcode": "8901234567890"
```

```
}
```

Acceptance Criteria

- Accepts decoded barcode string
- Queries indexed Medicine Barcodes table for a match
- Returns full medicine record if found
- Returns MEDICINE_NOT_FOUND error if no match
- Response within 2 seconds

Business Value

Fastest verification path — instant medicine lookup via barcode scan.

US-10 Retrieve a Specific Verification Result

User Story

As a **authenticated user**, I want to retrieve a verification result by its unique ID so that I can review the full details of a specific past check.

API Endpoint

GET /api/server/medicine/result/<id>/ Auth: **JWT**

Acceptance Criteria

- Returns full result data for the given ID
- User can only access their own results
- Returns HTTP 404 if ID not found
- Returns HTTP 403 if result belongs to another user

Business Value

Enables detailed review of any past verification for reference or evidence.

US-11 Search Medicine by Name

User Story

As a **user**, I want to search medicines using a name query parameter so that I can browse medicine records before verifying.

API Endpoint

GET /api/server/medicine/search/?q=<name> Auth: **JWT**

Acceptance Criteria

- Accepts query param ?q= for search term
- Returns matching medicine records from database

- Search indexed by medicine name for fast retrieval
- Empty query string returns HTTP 400

Business Value

Supports exploratory browsing of the medicine dataset.

US-12 Get Full Medicine Record Details

User Story

As a **user**, I want to view the complete details of a medicine record by ID so that I can read its full composition, legality, manufacturer, and description.

API Endpoint

GET /api/server/medicine/<id>/ Auth: **JWT**

Acceptance Criteria

- Returns all medicine fields: name, brand, manufacturer, composition, description
- Includes legality ENUM (Legal / Banned / Restricted / Under Review)
- Returns HTTP 404 if medicine ID is not found

Business Value

Provides comprehensive medicine information to support verification decisions.

OCR & Barcode Processing (US-13 – US-16)

US-13 Extract Raw Text from Medicine Image (OCR)

User Story

As a **medicine service**, I want to send an image to the OCR engine and receive the extracted raw text so that downstream agents can parse it for medicine fields.

API Endpoint

POST /api/server/ocr/extract/ Auth: **JWT**

Example Request

```
Form-data:
  image: <medicine_image.jpg>
```

Acceptance Criteria

- Forwards image to Google Vision API
- Returns raw extracted text string
- Returns 400 with a description for unreadable images

- Does not parse — returns raw OCR output only

Business Value

The raw text layer that all parsing and verification steps depend on.

US-14 Parse OCR Text into Structured Fields

User Story

As a **medicine service**, I want to parse raw OCR text to extract MFG, EXP, and MRP fields so that verification logic can use structured dates for expiry comparison.

API Endpoint

POST /api/server/ocr/parse-medicine/ Auth: **JWT**

Example Request

```
{
  "ocr_text": "MFG: Jan 2024 EXP: Dec 2025 MRP: Rs.45"
}
```

Acceptance Criteria

- Accepts raw OCR text string
- Applies Regex to detect MFG date, EXP date, and MRP
- Returns structured JSON with extracted fields
- Returns null for any undetected field

Business Value

Converts unstructured OCR output into actionable fields for verification logic.

US-15 Decode a Barcode Image

User Story

As a **user / medicine service**, I want to upload a barcode image and receive its decoded value so that the value is available for medicine lookup.

API Endpoint

POST /api/server/barcode/decode/ Auth: **JWT**

Example Request

```
Form-data:
  image: <barcode_image.jpg>
```

Acceptance Criteria

- Processes image using pyzbar library

- Returns decoded barcode value and type (EAN / UPC)
- Returns HTTP 400 if barcode is unreadable or not found

Business Value

Provides the barcode decoding step that powers the barcode verification flow.

US-16 Look Up Medicine by Barcode Value

User Story

As a **medicine service**, I want to query the database using a decoded barcode string so that the associated medicine record is retrieved instantly.

API Endpoint

GET /api/server/barcode/lookup/<barcode>/ Auth: **JWT**

Acceptance Criteria

- Queries indexed Medicine Barcodes table by barcode value
- Returns associated medicine record on match
- Returns HTTP 404 with MEDICINE_NOT_FOUND if no match
- Lookup completes within 2 seconds

Business Value

Enables sub-2-second medicine identification using a barcode as the lookup key.

RAG & FAISS Semantic Search (US-17 – US-19)

US-17 Perform FAISS Semantic Similarity Search

User Story

As a **medicine verification service**, I want to convert a query into an embedding and search the FAISS index so that the most semantically relevant medicine records are returned for verification.

API Endpoint

POST /api/server/rag/search/ Auth: **JWT**

Example Request

```
{
  "query": "Paracetamol tablet 500mg Cipla"
}
```

Acceptance Criteria

- Converts input to embedding via Sentence Transformers
- Performs similarity search on FAISS index

- Returns top-K matches with similarity scores
- Completes within 5 seconds under normal load
- Returns empty list (not error) if no match exceeds threshold

Business Value

Powers the core intelligent medicine matching beyond exact name lookup.

US-18 Check FAISS Index Health

User Story

As a **developer / system operator**, I want to query the FAISS index status endpoint so that I can confirm the index is loaded, its record count, and embedding dimension.

API Endpoint

GET /api/server/rag/index/status/ Auth: **JWT**

Acceptance Criteria

- Returns record count, embedding dimension, and last build timestamp
- Returns index status: healthy or degraded
- Returns HTTP 503 if index is not loaded

Business Value

Proactive monitoring of the FAISS index to prevent silent search failures.

US-19 Trigger FAISS Index Rebuild (Admin Only)

User Story

As a **admin**, I want to trigger a rebuild of the FAISS index from the latest medicine dataset so that newly added medicines become searchable without restarting any service.

API Endpoint

POST /api/server/rag/index/rebuild/ Auth: **JWT (Admin)**

Example Request

```
{
  "confirm": true
}
```

Acceptance Criteria

- Requires admin role — returns HTTP 403 for regular users
- Rebuilds FAISS index from current medicines table
- Saves new index to persistent Docker volume
- Returns rebuild status and number of records indexed

Business Value

Keeps the FAISS index in sync with new medicine data without downtime.

Symptom Remedy LLM Module (US-20 – US-23)

US-20 Submit Symptoms and Receive Home Remedy

User Story

As a **user**, I want to enter my symptoms as text and receive safe home remedy suggestions so that I can manage minor health issues with safe, informational guidance.

API Endpoint

POST /api/server/symptom/remedy/ Auth: **JWT**

Example Request

```
{
  "symptoms": "Sore throat and mild fever since yesterday."
}
```

Acceptance Criteria

- User submits free-text symptom description
- Input is passed to Ollama LLM with strict safety prompt
- Response includes: remedy, proportions, precautions, and disclaimer
- Response must NOT contain diagnosis, prescription drugs, or emergency advice
- Mandatory disclaimer: 'For informational purposes only — not a substitute for medical advice.'
- Response returned within 10 seconds; timeout handled with 503

Business Value

Provides AI-powered home remedy guidance with strict built-in safety guardrails.

US-21 View Symptom Query History

User Story

As a **authenticated user**, I want to view my past symptom queries and generated remedies so that I can refer back to previous suggestions without re-entering symptoms.

API Endpoint

GET /api/server/symptom/history/ Auth: **JWT**

Acceptance Criteria

- Returns symptom history entries for the authenticated user only
- Each entry includes symptom text, LLM response, and timestamp

- Ordered by most recent entry first
- Returns empty array if logging is disabled

Business Value

Gives users a personal record of past health queries for quick reference.

US-22 Clear All Symptom History

User Story

As a **authenticated user**, I want to delete all my past symptom history so that I can maintain complete privacy over my personal health queries.

API Endpoint

DELETE /api/server/symptom/history/clear/ Auth: **JWT**

Acceptance Criteria

- Deletes all symptom history for the authenticated user only
- Does not affect any other user's data
- Returns HTTP 200 with count of deleted records

Business Value

Supports user privacy by enabling full erasure of personal symptom data.

US-23 Check Ollama LLM Service Health

User Story

As a **developer / system operator**, I want to query the Ollama LLM service health endpoint so that I can detect service downtime before it affects end users.

API Endpoint

GET /api/server/symptom/llm/status/ Auth: **JWT**

Acceptance Criteria

- Pings the Ollama runtime
- Returns model name, availability (up/down), and response latency
- Returns HTTP 503 with error detail if Ollama is unreachable

Business Value

Enables real-time LLM monitoring to support proactive alerting.

Verification History (US-24 – US-28)

US-24 View All Verification History

User Story

As a **authenticated user**, I want to view a list of all my past medicine verification attempts so that I can track which medicines I have checked and their results.

API Endpoint

GET /api/server/history/ Auth: **JWT**

Acceptance Criteria

- Returns all verification history for the authenticated user only
- Includes input type, result status, and timestamp per entry
- Ordered by most recent first
- Returns empty list (not error) if no history exists

Business Value

Gives users a complete audit trail of all medicine checks on the platform.

US-25 Retrieve Single History Entry

User Story

As a **authenticated user**, I want to retrieve a specific history entry by its ID so that I can see all details including similarity score and raw input.

API Endpoint

GET /api/server/history/<id>/ Auth: **JWT**

Acceptance Criteria

- Returns full entry: input type, raw input, similarity score, result status, medicine details
- User can only access entries that belong to them
- Returns HTTP 404 if not found; HTTP 403 if owned by another user

Business Value

Detailed insight into any past verification, useful for tracking suspicious medicines.

US-26 Delete a Specific History Entry

User Story

As a **authenticated user**, I want to delete a specific verification history entry so that I can remove records I no longer want to keep.

API Endpoint

DELETE /api/server/history/<id>/delete/ Auth: **JWT**

Acceptance Criteria

- Deletes entry only if it belongs to the authenticated user
- Returns HTTP 403 if entry belongs to another user
- Returns HTTP 404 if entry does not exist
- Returns HTTP 200 with success message on deletion

Business Value

Gives users direct control over their personal verification data.

US-27 Clear All Verification History

User Story

As a **authenticated user**, I want to clear all my verification history in a single action so that I can reset all my records quickly.

API Endpoint

DELETE /api/server/history/clear/ Auth: **JWT**

Acceptance Criteria

- Bulk deletes all history entries for the authenticated user only
- Does not affect any other user's data
- Returns HTTP 200 with count of deleted records

Business Value

Enables bulk privacy control over all verification records.

US-28 View Verification Statistics

User Story

As a **authenticated user**, I want to view summary statistics of my verifications grouped by result status so that I can understand how many medicines I have verified per category.

API Endpoint

GET /api/server/history/stats/ Auth: **JWT**

Acceptance Criteria

- Returns counts grouped by: Authentic, Fake, Expired, Illegal, Not Found
- Scoped to the authenticated user only
- Returns zero (not missing key) for statuses with no records

Business Value

File Upload Service (US-29 – US-30 / US-31)

US-29 Upload Medicine or Barcode Image

User Story

As a **user**, I want to upload a medicine or barcode image to the file service so that it can be processed by OCR or barcode verification services.

API Endpoint

POST /api/server/files/upload/ Auth: **JWT**

Example Request

```
Form-data:
  file: <medicine_image.jpg>
```

Acceptance Criteria

- Accepts JPG and PNG files only — rejects other types with HTTP 400
- Validates file size against configured limit
- Stores file and metadata in the database
- Returns file ID and URL on HTTP 201
- Rejects potentially malicious uploads via file type validation

Business Value

Centralises image storage and provides a reusable URL for downstream processing.

US-30 Retrieve Uploaded File Metadata

User Story

As a **medicine / OCR service**, I want to fetch metadata for an uploaded file by its ID so that the file URL is available for downstream processing without re-upload.

API Endpoint

GET /api/server/files/<id>/ Auth: **JWT**

Acceptance Criteria

- Returns file ID, URL, upload timestamp, and file type
- Returns HTTP 404 if file does not exist
- User can only access metadata for files they uploaded

Business Value

Enables downstream services to resolve uploaded file URLs efficiently.

US-31 Delete an Uploaded File

User Story

As a **authenticated user**, I want to delete an uploaded image file so that I can remove sensitive images and free up storage.

API Endpoint

DELETE /api/server/files/<id>/delete/ Auth: **JWT**

Acceptance Criteria

- Deletes file from storage and removes metadata from DB
- Returns HTTP 403 if file belongs to another user
- Returns HTTP 404 if file does not exist
- Returns HTTP 200 with success message on deletion

Business Value

Gives users control over uploaded files and storage usage.

Core & Health Check (US-31 – US-33)

US-32 Overall System Health Check

User Story

As a **system operator / monitoring tool**, I want to query the overall health endpoint so that I can confirm all services are running before go-live or during monitoring.

API Endpoint

GET /api/server/core/health/ Auth: **Public**

Acceptance Criteria

- Aggregates health of PostgreSQL, FAISS, and Ollama
- Returns overall status: healthy or degraded
- No JWT required — accessible by monitoring tools
- HTTP 200 for healthy; HTTP 503 for degraded

Business Value

Single health signal for the entire platform, enabling rapid production monitoring.

US-33 Individual Service Health Checks

User Story

As a *developer / system operator*, I want to query individual health endpoints for PostgreSQL, FAISS, and Ollama so that I can quickly isolate which service has an issue.

API Endpoint

GET /api/server/core/health/db | /faiss | /llm Auth: **Public**

Acceptance Criteria

- Three separate endpoints independently check each service
- HTTP 200 with service info if up; HTTP 503 if down
- No JWT required — accessible by external monitoring systems

Business Value

Granular diagnostics to pinpoint failing services immediately during incidents.